

TJSC 2026 - Analista de Sistemas

# Segurança da Informação e Governança de TI

## Aula 2 - Criptografia, Hash, Assinatura Digital, Certificados Digitais e PKI

Material original, orientado ao edital retificado e ao padrão de cobrança da FGV, com teoria objetiva, tabelas comparativas, pegadinhas, 20 questões autorais comentadas, flashcards e checklist de memorização.

|       |                                                                                                   |
|-------|---------------------------------------------------------------------------------------------------|
| Cargo | Analista de Sistemas - TJSC                                                                       |
| Banca | Fundação Getulio Vargas - FGV                                                                     |
| Bloco | Segurança da Informação e Governança de TI                                                        |
| Aula  | 2 de 8                                                                                            |
| Foco  | Criptografia, hash, assinatura digital, certificados digitais e infraestrutura de chaves públicas |

Como estudar esta aula: leia a teoria em blocos de 25 a 35 minutos, marque somente as diferenças entre termos parecidos e resolva as questões sem olhar o gabarito. O ganho de ponto aqui vem de distinguir: criptografia x hash x assinatura; chave simétrica x assimétrica; certificado x assinatura; AC x AR; LCR x OCSP; TLS x PKI.

## Roteiro da aula

Esta aula cobre o núcleo criptográfico do bloco de Segurança da Informação. Embora o edital do TJSC liste explicitamente autenticação, autorização, gestão de identidade, SSO, OAuth2, OpenID Connect e Keycloak, a compreensão de certificados, chaves e assinaturas é pré-requisito para TLS, autenticação federada, APIs seguras, assinatura de documentos eletrônicos e trilhas de auditoria.

| Seção                    | O que você precisa dominar para a FGV                                                                         |
|--------------------------|---------------------------------------------------------------------------------------------------------------|
| 1. Criptografia          | Diferença entre criptografia simétrica e assimétrica; uso correto em repouso, trânsito e troca de chaves.     |
| 2. Hash e MAC            | Hash não criptografa; hash detecta alteração. MAC e HMAC adicionam chave secreta e autenticidade da mensagem. |
| 3. Assinatura digital    | Fluxo: resumo/hash do documento + chave privada do signatário + verificação com chave pública.                |
| 4. Certificados digitais | Certificado vincula uma identidade a uma chave pública, emitido por Autoridade Certificadora confiável.       |
| 5. PKI / ICP-Brasil      | Hierarquia de confiança, AC Raiz, AC intermediária, AR, LCR, OCSP, carimbo do tempo e cadeia de certificação. |
| 6. Questões FGV          | Enunciados situacionais com alternativas verossímeis, evitando respostas óbvias.                              |

Alvo prático: quando aparecer um cenário de API bancária, documento assinado, certificado vencido, rotação de chave, comunicação TLS ou armazenamento de senha, você deve identificar qual mecanismo criptográfico resolve qual propriedade de segurança.

## Tabela de siglas e acrônimos da aula

| Sigla     | Expansão                                                      | Como inferir em prova                                                                                     |
|-----------|---------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|
| AES       | Advanced Encryption Standard                                  | Padrão de cifra simétrica de bloco; confidencialidade com chave compartilhada.                            |
| RSA       | Rivest-Shamir-Adleman                                         | Algoritmo assimétrico usado historicamente para assinatura e troca/encapsulamento de chaves.              |
| ECC       | Elliptic Curve Cryptography                                   | Criptografia de curva elíptica; tende a oferecer chaves menores para segurança equivalente.               |
| ECDSA     | Elliptic Curve Digital Signature Algorithm                    | Assinatura digital com curvas elípticas.                                                                  |
| EdDSA     | Edwards-Curve Digital Signature Algorithm                     | Assinatura digital moderna baseada em curvas de Edwards.                                                  |
| SHA       | Secure Hash Algorithm                                         | Família de funções hash; SHA-256 aparece muito em provas.                                                 |
| HMAC      | Hash-based Message Authentication Code                        | Código de autenticação de mensagem baseado em hash e chave secreta.                                       |
| PKI       | Public Key Infrastructure                                     | Infraestrutura de chaves públicas: certificados, autoridades, políticas e revogação.                      |
| CA / AC   | Certification Authority / Autoridade Certificadora            | Entidade que emite e assina certificados digitais.                                                        |
| RA / AR   | Registration Authority / Autoridade de Registro               | Entidade que identifica/valida o titular antes da emissão do certificado.                                 |
| CRL / LCR | Certificate Revocation List / Lista de Certificados Revogados | Lista periódica de certificados revogados antes do vencimento.                                            |
| OCSP      | Online Certificate Status Protocol                            | Consulta online do estado de revogação de um certificado.                                                 |
| CSR       | Certificate Signing Request                                   | Solicitação de assinatura de certificado, geralmente contendo chave pública e dados do requerente.        |
| SAN       | Subject Alternative Name                                      | Extensão do certificado que lista nomes DNS, IPs ou identidades alternativas.                             |
| TLS       | Transport Layer Security                                      | Protocolo de segurança em trânsito; usa certificados, chaves e algoritmos.                                |
| mTLS      | mutual Transport Layer Security                               | TLS mútuo: cliente e servidor apresentam certificados.                                                    |
| KMS       | Key Management System                                         | Sistema de gerenciamento de chaves; ciclo de vida, rotação, guarda e auditoria.                           |
| HSM       | Hardware Security Module                                      | Módulo físico/criptográfico para proteger chaves sensíveis.                                               |
| PFS       | Perfect Forward Secrecy                                       | Sigilo futuro: comprometimento de chave de longo prazo não revela sessões antigas.                        |
| KDF       | Key Derivation Function                                       | Função de derivação de chaves; usada para derivar chaves a partir de segredo, senha ou material de chave. |

# 1. Criptografia: ideia central e propriedades de segurança

Criptografia é o conjunto de técnicas destinado a transformar informação de modo que apenas partes autorizadas consigam interpretá-la, validá-la ou associá-la a uma identidade. Para prova, o ponto decisivo não é decorar algoritmos isoladamente, mas saber qual mecanismo entrega qual propriedade: confidencialidade, integridade, autenticação, autoria, não repúdio, controle de acesso ou proteção de chaves.

Em sistemas corporativos, a criptografia aparece em três planos: dados em trânsito, dados em repouso e dados em uso/controle. Em uma API Java/Quarkus exposta por HTTPS, Transport Layer Security (TLS) protege o canal; em um banco de dados, criptografia em repouso protege arquivos ou colunas; em uma assinatura digital de documento, a chave privada do signatário gera uma assinatura verificável pela chave pública.

| Objetivo            | Mecanismo típico                                                                                   | Exemplo em sistema corporativo                                                                 | Pegadinha FGV                                                                        |
|---------------------|----------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|
| Confidencialidade e | Criptografia simétrica, TLS, criptografia de disco/coluna                                          | Payload sensível trafegando por HTTPS; base de dados criptografada em repouso                  | Hash não garante confidencialidade.                                                  |
| Integridade         | Hash, MAC, assinatura digital                                                                      | Detectar alteração de arquivo, mensagem ou documento                                           | Hash puro detecta alteração, mas não autentica origem.                               |
| Autenticidade       | Certificado, assinatura digital, MAC, autenticação forte                                           | Validar que um servidor é o domínio correto ou que um documento foi assinado por certo titular | Certificado não é a assinatura do documento; ele vincula identidade a chave pública. |
| Não repúdio         | Assinatura digital com chave privada sob controle exclusivo do titular, com políticas e evidências | Documento eletrônico assinado com certificado ICP-Brasil                                       | MAC não gera não repúdio, pois a chave é compartilhada.                              |
| Sigilo do canal     | TLS com certificado de servidor e chaves de sessão                                                 | Front Angular acessando backend por HTTPS                                                      | TLS não torna seguro um backend com autorização falha.                               |

## 1.1 Cifra, texto claro e texto cifrado

Texto claro, ou plaintext, é a informação legível antes da cifragem. Texto cifrado, ou ciphertext, é o resultado da aplicação de um algoritmo criptográfico com uma chave. Decifrar é retornar do ciphertext ao plaintext. A FGV costuma explorar erros de terminologia: hash não é cifra, assinatura digital não é criptografia de confidencialidade e certificado não é chave privada.

Regra de prova: se a alternativa disser que hash 'criptografa' ou permite 'recuperar o texto original', desconfie. Função hash criptográfica é unidirecional: gera resumo de tamanho fixo e não deve permitir reconstruir a entrada.

## 1.2 Criptografia boa não depende de esconder o algoritmo

A segurança moderna assume que o algoritmo pode ser conhecido publicamente. O segredo deve residir na chave, não no algoritmo. Isso é particularmente importante em ambiente público e bancário: usar algoritmo próprio, sem análise pública, costuma ser má prática. A escolha deve recair sobre algoritmos padronizados, bibliotecas confiáveis e parâmetros adequados.

Na prática de desenvolvimento, isso significa evitar 'criptografia caseira'. Em Java, por exemplo, o problema raramente é a ausência de bibliotecas; o problema é usar modo inseguro, IV fixo, chave

hardcoded, aleatoriedade fraca, armazenamento incorreto de senha ou rotação inexistente de chaves.

## 2. Criptografia simétrica

Na criptografia simétrica, **a mesma chave secreta é usada para cifrar e decifrar**. Ela é rápida e adequada para grandes volumes de dados. O problema central é a distribuição e proteção da chave: se a mesma chave precisa ser conhecida por quem cifra e por quem decifra, seu compartilhamento seguro vira parte essencial do desenho da solução.

O Advanced Encryption Standard (AES) é exemplo clássico de cifra simétrica de bloco. Em provas, AES geralmente aparece associado a confidencialidade, desempenho e uso de uma chave secreta compartilhada. O National Institute of Standards and Technology (NIST) descreve o AES como uma cifra simétrica de bloco capaz de cifrar e decifrar informação para proteger dados eletrônicos.

|                     |                                                                         |
|---------------------|-------------------------------------------------------------------------|
| Característica      | Criptografia simétrica                                                  |
| Chave               | Uma chave secreta compartilhada.                                        |
| Velocidade          | Alta; adequada para arquivos, bancos, volumes de tráfego e sessões TLS. |
| Uso típico          | Cifrar dados em repouso e dados de sessão.                              |
| Principal desafio   | Distribuição, rotação, guarda e revogação da chave secreta.             |
| Exemplo             | AES-128, AES-192, AES-256.                                              |
| Não fornece sozinha | Autoria pública ou não repúdio.                                         |

### 2.1 Modos de operação e IV

**Cifras de bloco operam em blocos de tamanho fixo. Por isso, são usadas com modos de operação.** Em prova, a FGV pode não exigir cálculo, mas pode cobrar a ideia de que o modo de operação influencia segurança. Um modo inadequado pode revelar padrões; um vetor de inicialização, Initialization Vector (IV), fixo ou reutilizado indevidamente pode enfraquecer a segurança.

| Item                        | Ideia que cai em prova                                                    | Erro comum                                                                                                             |
|-----------------------------|---------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|
| ECB - Electronic Codebook   | Blocos iguais geram blocos cifrados iguais; revela padrões.               | Achar que todo uso de AES é automaticamente seguro.                                                                    |
| CBC - Cipher Block Chaining | Encadeia blocos e exige IV imprevisível/único conforme contexto.          | Reutilizar IV ou tratar IV como senha.                                                                                 |
| GCM - Galois/Counter Mode   | Modo autenticado: confidencialidade e integridade/autenticidade da cifra. | Confundir com hash puro.                                                                                               |
| IV / nonce                  | Valor auxiliar para evitar repetição de padrões.                          | Guardar como segredo absoluto; em muitos modos, ele pode ser público, mas deve ser único/imprevisível conforme o modo. |

### 2.2 Criptografia autenticada

Criptografia autenticada combina confidencialidade com verificação de integridade/autenticidade do **ciphertext**. Em termos práticos, evita o cenário em que o dado está cifrado, mas alguém consegue alterar bits e explorar a aplicação ao decifrar. AES-GCM é o exemplo mais lembrado em segurança aplicada.

Ponto de ROI: para a FGV, 'criptografar' não basta. Uma alternativa tecnicamente mais forte pode falar em cifra autenticada, gerenciamento de chaves, rotação, KMS ou HSM. Isso é mais realista do que apenas 'usar AES'.

### 3. Criptografia assimétrica

Na criptografia assimétrica, há um **par de chaves matematicamente relacionadas**: chave **pública** e chave **privada**. A chave pública pode ser divulgada; a chave privada deve permanecer sob controle exclusivo do titular. Esse modelo resolve parte do problema de distribuição de chaves e permite assinatura digital, troca de chaves, autenticação e certificados.

| Uso                           | Chave usada na operação                    | Chave usada na verificação/operação inversa | Propriedade principal                                   |
|-------------------------------|--------------------------------------------|---------------------------------------------|---------------------------------------------------------|
| Cifrar para confidencialidade | Chave pública do destinatário              | Chave privada do destinatário               | Somente o destinatário deve conseguir decifrar.         |
| Assinar digitalmente          | Chave privada do signatário                | Chave pública do signatário                 | Qualquer verificador pode checar autoria e integridade. |
| Estabelecer chave de sessão   | Parâmetros assimétricos / acordo de chaves | Parâmetros complementares                   | Criar segredo de sessão sem transmiti-lo diretamente.   |

#### 3.1 O erro clássico: inverter assinatura com criptografia

Uma confusão recorrente em prova é dizer que a assinatura digital consiste em cifrar o documento inteiro com a chave pública do destinatário. Isso está errado. Assinatura digital é gerada com a chave privada do signatário e verificada com sua chave pública. Em geral, **assina-se um resumo criptográfico do documento, não necessariamente o documento completo**.

#### 3.2 Híbrido: assimétrica para combinar segredo, simétrica para trafegar dados

Protocolos seguros geralmente combinam os dois mundos. **A criptografia assimétrica ajuda na autenticação e no estabelecimento de segredo; a criptografia simétrica protege o volume de dados com desempenho maior**. TLS é o exemplo mental mais útil: certificado autentica o servidor, acordo de chaves cria chaves de sessão, e algoritmos simétricos protegem a comunicação.

| Comparação            | Simétrica                       | Assimétrica                                 |
|-----------------------|---------------------------------|---------------------------------------------|
| Quantidade de chaves  | Uma chave secreta compartilhada | Par de chaves: pública e privada            |
| Desempenho            | Mais rápida                     | Mais custosa computacionalmente             |
| Distribuição de chave | Mais difícil em larga escala    | Facilita distribuição da chave pública      |
| Assinatura digital    | Não resolve não repúdio         | Permite assinatura verificável publicamente |
| Uso em TLS            | Protege dados de sessão         | Autentica e ajuda no acordo de chaves       |

## 4. Hash criptográfico

Função hash criptográfica recebe uma entrada de tamanho arbitrário e produz um resumo, digest, de tamanho fixo. Ela deve ser determinística, eficiente e resistente a preimagem, segunda preimagem e colisão. O NIST define hash como algoritmo que mapeia mensagem de tamanho arbitrário para um resumo de tamanho fixo; esse resumo ajuda a detectar alterações na mensagem.

| Propriedade                | Tradução para prova                                                              | Exemplo de pegadinha                                                   |
|----------------------------|----------------------------------------------------------------------------------|------------------------------------------------------------------------|
| Determinismo               | A mesma entrada gera o mesmo digest.                                             | Se mudar 1 bit, o digest deve mudar de forma imprevisível.             |
| Preimage resistance        | Dado um digest, deve ser impraticável achar uma mensagem que gere aquele digest. | Hash não é reversível.                                                 |
| Second preimage resistance | Dada uma mensagem, deve ser impraticável achar outra com o mesmo digest.         | Não basta dizer que 'dificulta' alteração; a propriedade é específica. |
| Collision resistance       | Deve ser impraticável achar duas mensagens quaisquer com o mesmo digest.         | Colisão não é senha errada; é duas entradas gerando o mesmo hash.      |

### 4.1 Hash não é criptografia de confidencialidade

Hash não tem chave por padrão e não permite recuperar a entrada original. Por isso, não se deve dizer que 'criptografa' dados. Ele é usado para integridade, identificação de conteúdo, assinatura digital e armazenamento seguro de senhas quando combinado com sal, custo adaptativo e algoritmos próprios para senha.

### 4.2 SHA-1, SHA-2 e SHA-3

A família Secure Hash Algorithm (SHA) é recorrente. O NIST lista SHA-1 e a família SHA-2 no FIPS 180-4, e informa que o uso de SHA-1 foi depreciado e desautorizado para assinaturas digitais ao fim de 2013. Em concurso, a conclusão prática é: SHA-1 é legado/inseguro para assinatura; SHA-256 e SHA-3 são opções modernas mais plausíveis.

| Algoritmo/família | O que lembrar                                                   | Risco de prova                                                              |
|-------------------|-----------------------------------------------------------------|-----------------------------------------------------------------------------|
| MD5               | Legado, colisões conhecidas; inadequado para segurança moderna. | A alternativa pode falar em 'rápido', mas rapidez não compensa fragilidade. |
| SHA-1             | Depreciado; não usar para assinatura digital moderna.           | Pode aparecer como alternativa antiga em PKI.                               |
| SHA-2             | Inclui SHA-224, SHA-256, SHA-384, SHA-512.                      | SHA-256 é o nome mais provável em cenários práticos.                        |
| SHA-3             | Família mais nova baseada em Keccak; alternativa à SHA-2.       | Não confundir com 'versão 3 da SHA-2'.                                      |

### 4.3 Hash de senha: sal e função lenta

Armazenar senha exige cuidado especial. Não se deve armazenar senha em texto claro, nem apenas aplicar hash rápido genérico sem sal. Sal, salt, é valor aleatório por senha para impedir tabelas pré-computadas e reduzir o impacto de senhas iguais. Funções de derivação ou hash de senha, como Argon2, bcrypt, scrypt ou PBKDF2, aumentam o custo de ataque offline.

Aplicação no seu mundo Java/Quarkus: senha de usuário não deve ser 'criptografada para depois descriptografar'. O padrão é armazenar verificador: hash de senha com sal e custo. Login compara nova tentativa processada com o verificador armazenado.

## 5. MAC, HMAC e integridade autenticada

Message Authentication Code (MAC) é um código de autenticação de mensagem calculado com chave secreta. Diferentemente de hash puro, MAC permite que quem conhece a chave verifique se a mensagem veio de alguém que também conhece a chave e se não foi alterada. Hash-based Message Authentication Code (HMAC) é uma construção de MAC baseada em função hash.

| Mecanismo          | Tem chave?                       | Garante integridade?                                                 | Autentica origem?                          | Gera não repúdio?                                     |
|--------------------|----------------------------------|----------------------------------------------------------------------|--------------------------------------------|-------------------------------------------------------|
| Hash puro          | Não                              | Sim, contra alterações acidentais ou comparação com digest confiável | Não por si só                              | Não                                                   |
| HMAC               | Sim, chave secreta compartilhada | Sim                                                                  | Sim, entre partes que compartilham a chave | Não, pois a chave é com partilhada                    |
| Assinatura digital | Sim, chave privada do signatário | Sim                                                                  | Sim, vinculada ao titular do par de chaves | Pode gerar, com contexto jurídico e proteção da chave |

HMAC é muito usado em integrações, webhooks, APIs internas e autenticação de mensagens. Em uma API corporativa, por exemplo, o consumidor pode assinar logicamente uma requisição com HMAC usando segredo compartilhado. O servidor recalcula o HMAC e compara. Isso não prova para terceiros que apenas um lado assinou, porque ambos conhecem o segredo.

### 5.1 Quando a FGV tenta confundir

A banca pode apresentar três alternativas tecnicamente parecidas: hash, HMAC e assinatura digital. A resposta depende da propriedade exigida. Para detectar alteração sem origem, hash. Para autenticar mensagem entre partes com segredo compartilhado, HMAC. Para autoria verificável por terceiros, assinatura digital.

## 6. Assinatura digital

Assinatura digital é um mecanismo criptográfico que vincula uma mensagem ou documento a uma chave privada, permitindo verificação com a chave pública correspondente. Em termos de prova: assinatura digital busca garantir integridade, autenticidade/autoria e, em contexto adequado, não repúdio. Não serve primariamente para esconder o conteúdo do documento.

### 6.1 Fluxo conceitual

| Etapa                     | O que acontece                                                                    | Quem usa qual chave                                                   |
|---------------------------|-----------------------------------------------------------------------------------|-----------------------------------------------------------------------|
| 1. Resumo                 | Calcula-se o hash do documento ou mensagem.                                       | Não há chave no hash puro.                                            |
| 2. Assinatura             | O resumo é processado pelo algoritmo de assinatura.                               | Usa a chave privada do signatário.                                    |
| 3. Envio/armazenamento    | Documento, assinatura e certificado/cadeia podem ser encaminhados ou armazenados. | A chave privada não deve ser enviada.                                 |
| 4. Verificação            | Recalcula-se o hash do documento e valida-se a assinatura.                        | Usa a chave pública do signatário, normalmente obtida do certificado. |
| 5. Validação de confiança | Verifica-se cadeia de certificação, validade, revogação e política aplicável.     | Usa confiança em ACs e mecanismos como LCR/OCSP.                      |

### 6.2 Assinar não é cifrar para o destinatário

Se Ana assina digitalmente um contrato, ela usa sua chave privada. Quem recebe usa a chave pública de Ana para verificar a assinatura. O documento pode continuar legível; se também houver necessidade de confidencialidade, aplica-se criptografia adicional, por exemplo cifrando com chave simétrica protegida para o destinatário.

### 6.3 Algoritmos de assinatura

Algoritmos clássicos incluem RSA, Digital Signature Algorithm (DSA), Elliptic Curve Digital Signature Algorithm (ECDSA) e Edwards-Curve Digital Signature Algorithm (EdDSA). O NIST FIPS 186-5 aprova o uso de EdDSA e menciona HashEdDSA, versão em que a assinatura é gerada sobre o hash da mensagem. Para a prova, interessa menos calcular algoritmo e mais reconhecer o papel das chaves e do hash.

| Termo         | Uso em assinatura                      | Observação de prova                                                           |
|---------------|----------------------------------------|-------------------------------------------------------------------------------|
| Chave privada | Gera a assinatura                      | Deve ficar sob controle do titular; se compartilhada, enfraquece não repúdio. |
| Chave pública | Verifica a assinatura                  | Pode ser distribuída via certificado digital.                                 |
| Hash          | Resume a mensagem assinada             | Se o documento muda, o hash muda e a assinatura falha.                        |
| Certificado   | Vincula chave pública a uma identidade | Não é a chave privada nem a assinatura do documento.                          |

## 7. Certificados digitais

Certificado digital é uma **estrutura eletrônica** que vincula uma chave pública a uma identidade, sob assinatura de uma Autoridade Certificadora. Ele permite que terceiros confiem que determinada chave pública pertence a determinada entidade, desde que confiem na cadeia de certificação e que o certificado esteja válido e não revogado.

Em X.509, certificados possuem campos como sujeito, emissor, número de série, validade, chave pública, algoritmo de assinatura, extensões e assinatura da autoridade emissora. A RFC 5280 perfila certificados X.509 v3 e listas de revogação de certificados para uso na Internet, incluindo validação de caminho de certificação.

| Campo/elemento                  | Significado                                                             |
|---------------------------------|-------------------------------------------------------------------------|
| Subject / Sujeito               | Identidade do titular do certificado.                                   |
| Issuer / Emissor                | Autoridade Certificadora que emitiu o certificado.                      |
| Public Key / Chave pública      | Chave pública vinculada ao sujeito.                                     |
| Validity / Validade             | Período em que o certificado pode ser considerado temporalmente válido. |
| Serial Number / Número de série | Identificador único do certificado no contexto da AC emissora.          |
| Key Usage                       | Define usos permitidos da chave, como assinatura digital ou cifragem.   |
| Subject Alternative Name - SAN  | Nomes alternativos, especialmente nomes DNS em certificados TLS.        |
| Signature                       | Assinatura da AC emissora sobre os dados do certificado.                |

### 7.1 Certificado de servidor TLS

Quando seu navegador ou cliente Angular acessa uma API HTTPS, o servidor apresenta um certificado. O cliente verifica se o certificado foi emitido por uma autoridade confiável, se o nome acessado corresponde ao certificado, se está dentro da validade e se não há revogação relevante. Só depois disso o canal é estabelecido com parâmetros criptográficos seguros.

### 7.2 Certificado expirado, revogado ou emitido para outro nome

Certificado expirado não deve ser aceito como válido temporalmente. Certificado revogado foi invalidado antes do fim da validade, por exemplo por comprometimento de chave. Certificado emitido para outro nome não autentica corretamente o servidor pretendido. Em prova, a alternativa 'ignorar o alerta e prosseguir' quase sempre é ruim.

## 8. PKI - Public Key Infrastructure

Public Key Infrastructure (PKI), ou Infraestrutura de Chaves Públicas, é o conjunto de entidades, políticas, processos, tecnologias e repositórios que permite emitir, validar, revogar e confiar em certificados digitais. PKI não é apenas algoritmo: envolve governança, ciclo de vida, auditoria, práticas de certificação e cadeia de confiança.

| Componente                                   | Papel                                                                                     |
|----------------------------------------------|-------------------------------------------------------------------------------------------|
| Autoridade Certificadora Raiz - AC Raiz      | Ponto máximo de confiança da hierarquia. Assina certificados de autoridades subordinadas. |
| Autoridade Certificadora intermediária       | Emite certificados para titulares ou outras autoridades conforme políticas.               |
| Autoridade de Registro - AR                  | Identifica e valida dados do solicitante antes da emissão.                                |
| Repositório                                  | Publica certificados, políticas, LCRs e informações necessárias à validação.              |
| LCR / CRL                                    | Lista de certificados revogados, publicada periodicamente.                                |
| OCSP                                         | Consulta online do estado de revogação de certificado.                                    |
| Política de Certificado - PC                 | Define regras e usos para determinado tipo de certificado.                                |
| Declaração de Práticas de Certificação - DPC | Descreve como a AC implementa suas práticas.                                              |

### 8.1 Cadeia de certificação

Validação de certificado normalmente exige construir uma cadeia: certificado do titular -> AC intermediária -> AC raiz confiável. A confiança não decorre apenas do certificado final, mas da capacidade de verificar assinaturas intermediárias, políticas, validade temporal e revogação.

### 8.2 LCR versus OCSP

| Critério    | LCR / CRL                                                 | OCSP                                                    |
|-------------|-----------------------------------------------------------|---------------------------------------------------------|
| Modelo      | Lista publicada periodicamente                            | Consulta online por certificado                         |
| Vantagem    | Pode ser baixada e armazenada em cache                    | Resposta mais específica e potencialmente mais atual    |
| Desvantagem | Pode ficar pesada e menos atualizada                      | Depende de disponibilidade do respondedor               |
| Pegadinha   | Não é lista de certificados válidos; é lista de revogados | Não substitui validade temporal nem cadeia de confiança |

### 8.3 ICP-Brasil

No Brasil, a Infraestrutura de Chaves Públicas Brasileira (ICP-Brasil) organiza a cadeia de confiança nacional para certificados digitais. Em prova recente da própria FGV para Analista de Segurança da Informação no Judiciário, apareceu o Instituto Nacional de Tecnologia da Informação (ITI) relacionado à Autoridade Certificadora Raiz da ICP-Brasil. Portanto, esse é um tema com probabilidade real em contexto de TJ.

A página oficial do ITI reúne áreas de Certificação Digital, Autoridades de Registro, Carimbo do Tempo, ICP-Brasil e Validação de Assinaturas Eletrônicas. O serviço oficial de verificação de conformidade de assinaturas digitais ICP-Brasil é disponibilizado via web.

## 9. Carimbo do tempo, validade e não repúdio

Carimbo do tempo acrescenta evidência temporal confiável a um documento ou assinatura. A ideia é provar que determinado dado existia em certo momento e que a assinatura foi realizada ou validada dentro de uma janela temporal relevante. Em documentos de longa duração, isso é importante porque certificados expiram, algoritmos envelhecem e chaves podem ser revogadas.

| Situação                                                       | O que analisar                                                                                               |
|----------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| Certificado válido no momento da assinatura, mas expirado hoje | Pode ser necessário validar evidências temporais e cadeia no momento da assinatura, não apenas a data atual. |
| Chave privada comprometida                                     | A AC pode revogar o certificado; assinaturas posteriores ao comprometimento perdem confiabilidade.           |
| Assinatura sem carimbo do tempo                                | Pode haver dificuldade de provar quando a assinatura foi feita.                                              |
| Documento alterado após assinatura                             | A verificação da assinatura deve falhar, pois o hash recalculado difere do assinado.                         |

### 9.1 Não repúdio não é mágica

Não repúdio depende de assinatura digital, proteção da chave privada, políticas de certificação, trilhas de auditoria e contexto jurídico. Se a chave privada é compartilhada em um time, armazenada em repositório ou usada sem controle, a força probatória e técnica diminui. Por isso, em ambiente corporativo, a gestão de chaves é tão importante quanto o algoritmo.

## 10. Gestão de chaves criptográficas

Gestão de chaves é o conjunto de práticas para geração, armazenamento, distribuição, uso, rotação, arquivamento, revogação e destruição de chaves criptográficas. O NIST SP 800-57 fornece orientação de gerenciamento de material criptográfico, incluindo tipos de chaves, proteção exigida e funções de gestão de chaves.

| Fase                 | Boa prática                                                                 | Erro que cai em prova                                     |
|----------------------|-----------------------------------------------------------------------------|-----------------------------------------------------------|
| Geração              | Usar fonte de aleatoriedade forte e bibliotecas confiáveis.                 | Gerar chave com Random fraco ou valor previsível.         |
| Armazenamento        | Proteger em KMS, HSM, cofre de segredos ou mecanismo equivalente.           | Hardcoded em código-fonte, YAML, frontend ou repositório. |
| Distribuição         | Transportar por canal seguro e com controle de acesso.                      | Enviar chave por e-mail ou chat sem proteção.             |
| Uso                  | Restringir finalidade conforme política e key usage.                        | Usar a mesma chave para tudo indefinidamente.             |
| Rotação              | Trocar chaves conforme risco, expiração, incidente ou política.             | Nunca rotacionar ou não versionar chaves.                 |
| Revogação/destruição | Invalidar chaves comprometidas e destruir material secreto de forma segura. | Apenas apagar referência lógica sem controle.             |

### 10.1 KMS e HSM

Key Management System (KMS) é sistema para gerenciar o ciclo de vida de chaves. Hardware Security Module (HSM) é módulo criptográfico dedicado, geralmente usado para proteger chaves de alto valor e executar operações criptográficas sem expor material secreto. Em prova, HSM aparece como mecanismo forte para proteger chave privada de AC, servidor crítico ou assinatura de alto valor.

### 10.2 Segredos em pipelines e aplicações

Em DevSecOps, chaves, tokens e certificados não devem ser hardcoded. O correto é usar cofre de segredos, variáveis protegidas, rotação, trilha de auditoria e segregação por ambiente. Para Quarkus, Spring ou Angular, cuidado adicional: segredo no frontend não é segredo; qualquer valor entregue ao navegador pode ser extraído.

Hack de prova: quando o enunciado falar em 'chave privada em repositório', 'certificado compartilhado por todos os desenvolvedores' ou 'senha criptografada no código', procure alternativa de gestão de segredos, rotação, revogação e menor privilégio.

## 11. TLS, certificados e APIs

Transport Layer Security (TLS) é o protocolo que protege comunicações em trânsito, substituindo o antigo SSL. Em uma arquitetura de APIs, TLS autentica o servidor por certificado, negocia parâmetros criptográficos e protege o canal contra leitura e alteração por terceiros. Em mTLS, mutual TLS, o cliente também apresenta certificado, permitindo autenticação forte entre serviços.

| Cenário                             | Mecanismo adequado                                          | Observação                                                                             |
|-------------------------------------|-------------------------------------------------------------|----------------------------------------------------------------------------------------|
| Frontend Angular acessa API pública | HTTPS/TLS com certificado válido no servidor                | Protege canal, mas não substitui autenticação/autorização da aplicação.                |
| Comunicação serviço-serviço crítica | mTLS, rotação de certificados, identidade de workload       | Útil em microsserviços e malhas de serviço.                                            |
| Webhook entre sistemas              | TLS + HMAC ou assinatura de requisição                      | TLS protege o canal; HMAC/assinatura protege a mensagem.                               |
| Documento PDF assinado              | Assinatura digital + certificado + cadeia de validação      | Não depende de TLS depois que o arquivo está salvo.                                    |
| Token JWT assinado                  | Assinatura JWS com chave privada/secreto conforme algoritmo | Assinar token não cifra seu conteúdo; para confidencialidade, use JWE ou canal seguro. |

### 11.1 Certificado wildcard, SAN e nome do servidor

Em TLS moderno, a correspondência do nome do servidor deve considerar Subject Alternative Name (SAN). Um certificado emitido para `api.exemplo.gov.br` não autentica, por si só, `pagamentos.exemplo.gov.br`. Certificados wildcard podem cobrir subdomínios conforme regras específicas, mas não resolvem todos os níveis e nem substituem governança de emissão.

### 11.2 TLS não corrige falha de autorização

TLS protege contra interceptação e adulteração no transporte, mas não impede que um usuário autenticado acesse recurso que não deveria. Essa distinção será aprofundada na Aula 3, mas já importa aqui: criptografia de transporte não substitui controle de acesso, validação de escopo ou checagem de permissões no backend.

## 12. Pegadinhas FGV de alto retorno

| Pegadinha                                           | Como responder                                                                                          |
|-----------------------------------------------------|---------------------------------------------------------------------------------------------------------|
| Hash 'descriptor' senha                             | Errado. Hash não é reversível; senha é verificada comparando novo processamento com o valor armazenado. |
| Assinatura digital garante sigilo                   | Errado como regra. Assinatura garante integridade/autoria; sigilo exige criptografia.                   |
| Chave pública deve ser secreta                      | Errado. A chave pública é distribuível; a privada é secreta.                                            |
| MAC gera não repúdio                                | Errado. Como a chave é compartilhada, não prova autoria para terceiro.                                  |
| Certificado é a chave privada                       | Errado. Certificado contém chave pública e dados de identidade, assinado por AC.                        |
| Certificado válido no prazo basta                   | Incompleto. Também verificar cadeia, nome, uso permitido, revogação e políticas.                        |
| Criptografia caseira é segura se segredo for grande | Errado. Usar algoritmos e bibliotecas reconhecidas.                                                     |
| TLS dispensa autenticação da aplicação              | Errado. TLS protege canal; autorização é lógica da aplicação.                                           |
| LCR lista certificados válidos                      | Errado. LCR lista certificados revogados.                                                               |
| AES resolve assinatura digital                      | Errado. AES é simétrico e não fornece assinatura verificável por chave pública.                         |

### Mapa mental textual

- Criptografia simétrica -> uma chave -> rápida -> confidencialidade em volume -> AES.
- Criptografia assimétrica -> par de chaves -> chave pública e privada -> assinatura, certificados, acordo de chaves.
- Hash -> resumo fixo -> integridade -> não tem chave -> não cifra.
- HMAC -> hash + chave secreta -> integridade e autenticidade entre partes -> sem não repúdio.
- Assinatura digital -> hash + chave privada -> verifica com chave pública -> autoria/integridade/não repúdio contextual.
- Certificado -> identidade + chave pública + assinatura da AC -> confiança por cadeia.
- PKI -> pessoas, políticas, autoridades, certificados, repositórios e revogação.

## Lista de questões - sem gabarito

Resolva sem consultar o gabarito. As questões foram escritas com enunciados situacionais e distratores plausíveis para treinar o padrão FGV: a resposta correta raramente é apenas a alternativa com o termo mais famoso; ela costuma ser a alternativa mais completa, precisa e compatível com o cenário.

### Questão 01 - Criptografia simétrica e gestão de chaves

Um Tribunal pretende criptografar, em repouso, arquivos anexados a processos eletrônicos. A equipe de desenvolvimento propõe usar AES para cifrar os arquivos e armazenar a chave de cifragem diretamente no repositório Git privado do projeto, argumentando que o repositório exige autenticação corporativa e que a cifra escolhida é robusta. Sob a ótica de segurança da informação, a avaliação tecnicamente mais adequada é:

- A) a escolha do AES é suficiente, pois a robustez do algoritmo elimina a necessidade de proteção adicional da chave;
- B) o armazenamento da chave no repositório é aceitável se o projeto for privado e a branch principal possuir revisão por pull request;
- C) a escolha de uma cifra simétrica reconhecida pode ser adequada, mas a chave deve ser gerenciada em mecanismo próprio, com controle de acesso, rotação e auditoria;
- D) a cifragem deve ser substituída por hash SHA-256 dos arquivos, pois hash garante confidencialidade e reduz o risco de vazamento;
- E) a chave deve ser colocada no frontend para que cada usuário consiga decifrar localmente os arquivos com menor carga no servidor.

### Questão 02 - Assinatura digital

Uma API interna recebe documentos eletrônicos que devem ser assinados por servidores autorizados. O requisito principal é permitir que qualquer unidade competente verifique, posteriormente, se o documento foi assinado pelo titular da chave e se não foi alterado após a assinatura. O desenho criptográfico mais aderente a esse requisito é:

- A) gerar um hash do documento e assiná-lo com a chave privada do signatário, permitindo verificação com a chave pública correspondente e validação da cadeia de certificados;
- B) criptografar o documento com a chave pública do signatário, pois apenas ele poderá ter produzido o conteúdo decifrável com sua chave privada;
- C) calcular um HMAC com chave simétrica compartilhada por todas as unidades, pois isso prova de forma pública qual servidor assinou o documento;
- D) compactar o documento e aplicar codificação Base64, pois o resultado deixa de ser humanamente legível e se torna protegido;
- E) armazenar o documento em banco com controle transacional, pois a atomicidade da transação substitui a assinatura digital.

### Questão 03 - Hash e senha

Em revisão de código de um sistema administrativo, a equipe encontrou a seguinte prática: antes de gravar a senha do usuário, a aplicação calcula SHA-256(senha) e armazena o resultado. Não há sal individual, nem função de derivação com custo configurável. Considerando boas práticas de segurança aplicada, assinale a avaliação correta.

- A) A prática é adequada, pois SHA-256 é irreversível e, por isso, dispensa sal e fator de custo.
- B) A prática é inadequada apenas se o banco de dados não estiver criptografado em repouso; com criptografia de disco, o hash simples passa a ser suficiente.
- C) A prática deveria ser substituída por criptografia simétrica reversível, pois o sistema precisa recuperar a senha original para autenticar o usuário.
- D) A prática é adequada se as senhas forem transmitidas por HTTPS, pois o TLS protege também o armazenamento posterior no banco.
- E) A prática é fraca para armazenamento de senhas; deve-se usar sal por senha e função apropriada de derivação/hash de senha, com custo resistente a ataques offline.

### Questão 04 - Certificado digital

Durante a análise de um incidente, verificou-se que um serviço acessava <https://api.tj.exemplo>, mas aceitava certificado emitido para outro nome DNS, desde que a cadeia terminasse em uma autoridade confiável. A justificativa foi a de que a Autoridade Certificadora era reconhecida pelo sistema operacional. Nesse cenário, a conduta correta é:

- A) aceitar o certificado, pois a confiança na AC Raiz é o único critério relevante na validação TLS;
- B) rejeitar o certificado, pois a validação deve considerar também a correspondência entre o nome acessado e os nomes previstos no certificado, além de validade, cadeia e revogação;
- C) aceitar o certificado se ele estiver dentro do prazo de validade, ainda que emitido para outro nome, pois validade temporal prevalece sobre identidade;
- D) substituir TLS por hash do endpoint, pois hash elimina a necessidade de certificado de servidor;
- E) ignorar o erro apenas em ambiente de produção, pois ambientes críticos não podem depender de validação de nome.

### Questão 05 - Hash, HMAC e assinatura

Um fornecedor envia notificações de pagamento para uma API do órgão. O requisito é que o órgão consiga verificar que a mensagem não foi alterada e que foi gerada por alguém que conhece um segredo previamente compartilhado entre fornecedor e órgão. Não se exige prova pública de autoria perante terceiros. A solução mais aderente é:

- A) hash SHA-256 puro do corpo da mensagem, enviado em cabeçalho HTTP;
- B) criptografia assimétrica do corpo com a chave privada do fornecedor;
- C) certificado TLS autoassinado aceito sem validação de cadeia;
- D) HMAC calculado sobre a mensagem com chave secreta compartilhada e comparação segura no servidor;
- E) codificação Base64 do payload para impedir leitura e alteração por intermediários.

### Questão 06 - PKI e cadeia de confiança

Uma equipe afirma que, para validar uma assinatura digital baseada em certificado, basta conferir se o certificado do signatário ainda não atingiu sua data de expiração. A afirmação é tecnicamente insuficiente porque a validação adequada também deve considerar:

- A) apenas o tamanho do arquivo assinado, pois arquivos grandes exigem certificados de maior comprimento;
- B) se o certificado foi emitido no mesmo país em que o documento será armazenado, independentemente da cadeia;
- C) a cadeia de certificação, a assinatura da autoridade emissora, o uso permitido da chave, o estado de revogação e a política aplicável;
- D) somente a versão do algoritmo de compactação usado no documento antes da assinatura;
- E) a existência de criptografia simétrica no banco de dados, que substitui a verificação da cadeia de confiança.

### Questão 07 - Criptografia assimétrica

Um analista precisa explicar a desenvolvedores a diferença entre cifrar uma mensagem para confidencialidade e assinar digitalmente uma mensagem. A explicação correta é:

- A) para confidencialidade, cifra-se com a chave pública do destinatário e decifra-se com a chave privada dele; para assinatura, assina-se com a chave privada do signatário e verifica-se com a chave pública correspondente;
- B) para confidencialidade e assinatura, usa-se sempre a chave privada do destinatário, pois somente ela garante sigilo e autoria;
- C) para assinatura digital, a chave pública deve ficar secreta, pois sua divulgação permitiria forjar assinaturas;
- D) para confidencialidade, usa-se hash; para assinatura, usa-se compressão com certificado digital;
- E) a diferença é apenas jurídica, pois tecnicamente cifragem e assinatura executam o mesmo processo com as mesmas chaves.

**Questão 08 - LCR e OCSP**

Um certificado digital de servidor foi revogado antes do fim de sua validade em razão de suspeita de comprometimento da chave privada. Ao validar esse certificado, o cliente deve consultar mecanismos de estado de revogação. Nesse contexto, é correto afirmar que:

- A) a LCR é uma lista de certificados válidos emitidos pela Autoridade Certificadora;
- B) OCSP é usado para cifrar a comunicação TLS depois que o certificado foi validado;
- C) a revogação só produz efeito depois do vencimento natural do certificado;
- D) se a cadeia terminar em AC confiável, a consulta de revogação é proibida por violar privacidade;
- E) LCR e OCSP são mecanismos usados para verificar se um certificado foi revogado, com modelos operacionais distintos.

**Questão 09 - Criptografia autenticada**

Uma aplicação cifra registros sensíveis com AES em modo que não oferece autenticação do ciphertext. Em teste de segurança, verificou-se que alterações controladas em blocos cifrados podem causar comportamento inesperado após a decifragem. A recomendação mais precisa é:

- A) substituir AES por Base64, pois Base64 impede alteração binária do conteúdo;
- B) adotar modo de criptografia autenticada, como AES-GCM, ou composição segura equivalente, para proteger confidencialidade e integridade/autenticidade do ciphertext;
- C) remover o vetor de inicialização para tornar a cifragem determinística e facilitar auditoria;
- D) usar MD5 do ciphertext como chave de decifragem, pois isso vincula o conteúdo ao algoritmo;
- E) armazenar a chave no mesmo registro cifrado, pois assim a alteração do dado torna-se detectável.

**Questão 10 - TLS e autorização**

Uma auditoria apontou que todos os endpoints de uma API estão publicados exclusivamente em HTTPS com certificado válido, mas um usuário autenticado consegue consultar processos administrativos de outra unidade sem autorização. A defesa do time foi: 'o canal é criptografado, logo o acesso é seguro'. A análise correta é:

- A) a defesa procede, pois TLS garante confidencialidade, integridade e autorização de todos os recursos da aplicação;
- B) a defesa procede se o certificado TLS tiver sido emitido por AC pública, pois isso elimina a necessidade de autorização no backend;
- C) o problema deve ser resolvido substituindo HTTPS por HTTP assinado com hash SHA-1;
- D) TLS protege o canal de comunicação, mas não substitui controles de autorização e validação de escopo no servidor;
- E) a falha é apenas de disponibilidade, pois confidencialidade e autorização são propriedades equivalentes.

**Questão 11 - Certificado x assinatura**

Em reunião de projeto, um gerente afirma que 'um certificado digital é o próprio documento assinado, pois contém a assinatura da pessoa'. A correção técnica mais adequada é:

- A) a afirmação está correta, pois o certificado armazena todos os documentos assinados pelo titular;
- B) a afirmação está correta apenas quando o certificado é do tipo A3;
- C) o certificado digital vincula uma identidade a uma chave pública e é assinado por uma Autoridade Certificadora; a assinatura do documento é outro objeto criptográfico gerado com a chave privada do signatário;
- D) o certificado é uma senha simétrica usada para cifrar documentos, não tendo relação com chave pública;
- E) o certificado substitui a cadeia de confiança, dispensando validação de emissor e revogação.

**Questão 12 - Não repúdio**

Duas unidades de um órgão compartilham a mesma chave secreta para gerar HMACs de mensagens internas. Posteriormente, uma delas nega ter enviado determinada mensagem cujo HMAC é válido. Sob a perspectiva de não repúdio, a evidência é limitada porque:

- A) qualquer parte que conheça a chave secreta compartilhada poderia gerar o HMAC, diferentemente de uma assinatura digital baseada em chave privada sob controle exclusivo do signatário;
- B) HMAC não fornece integridade de mensagem, apenas confidencialidade;
- C) HMAC exige certificado ICP-Brasil e, sem ele, a mensagem é automaticamente inválida;
- D) o problema ocorreria apenas se o algoritmo de hash fosse SHA-512, pois esse algoritmo não permite autenticação;
- E) a chave pública do remetente deveria ter sido usada para gerar o HMAC.

**Questão 13 - ICP-Brasil e autoridades**

No contexto da ICP-Brasil, uma entidade é responsável por realizar a identificação presencial ou equivalente do solicitante e validar informações antes da emissão do certificado por uma autoridade certificadora. Essa função corresponde, em termos gerais, à:

- A) Autoridade de Carimbo do Tempo, cuja função principal é cifrar os documentos assinados;
- B) Lista de Certificados Revogados, cuja função é cadastrar novos titulares;
- C) Autoridade Certificadora Raiz, que atende diretamente todo usuário final em qualquer emissão;
- D) biblioteca criptográfica da aplicação, que substitui a validação de identidade;
- E) Autoridade de Registro, que atua no processo de identificação e validação do solicitante.

**Questão 14 - Chave privada comprometida**

Um desenvolvedor acidentalmente publicou em repositório um arquivo contendo a chave privada usada por um serviço para autenticação mTLS em ambiente de homologação. O repositório foi tornado privado minutos depois. A ação mais adequada é:

- A) manter a chave, pois o curto período de exposição elimina o risco de uso indevido;
- B) revogar/substituir o certificado associado, gerar novo par de chaves, rotacionar segredos relacionados e investigar acessos ao repositório e ao serviço;
- C) apenas trocar o nome do arquivo, pois a chave privada deixa de ser encontrada por ferramentas automáticas;
- D) publicar também a chave pública para equilibrar o risco criptográfico;
- E) aplicar hash na chave privada e continuar usando o arquivo original em produção.

**Questão 15 - JWT, assinatura e confidencialidade**

Uma equipe usa JSON Web Token (JWT) assinado para transportar claims de usuário entre aplicações. O token trafega em HTTPS, mas também pode ser visualizado por quem o possui. A equipe afirma que, por estar 'assinado', o conteúdo do token está automaticamente confidencial. A afirmação é:

- A) correta, pois assinatura digital e criptografia de conteúdo são sinônimos em tokens;
- B) correta se o algoritmo de assinatura for assimétrico;
- C) incorreta apenas quando o token usa SHA-256;
- D) incorreta, pois assinatura protege integridade/autenticidade do token, mas não cifra necessariamente seu conteúdo; confidencialidade exige criptografia ou proteção adequada do canal e do armazenamento;
- E) correta se o certificado do servidor TLS estiver válido.

**Questão 16 - Perfect Forward Secrecy**

Em uma revisão de configuração TLS, a equipe busca reduzir o impacto de eventual comprometimento futuro da chave privada de longo prazo do servidor. A propriedade desejada é que sessões passadas não sejam decifradas apenas com essa chave comprometida. Essa propriedade é conhecida como:

- A) criptografia determinística de sessão;
- B) lista de certificados revogados retroativa;
- C) Perfect Forward Secrecy, obtida por mecanismos de acordo de chaves efêmeras adequados;
- D) assinatura digital reversível;
- E) codificação assimétrica persistente.

**Questão 17 - PKI e path validation**

Um cliente recebeu o certificado final de um servidor, mas não recebeu o certificado intermediário necessário para construir a cadeia até uma raiz confiável. Mesmo que o certificado final esteja dentro da validade, a validação pode falhar porque:

- A) a confiança em PKI depende da construção e verificação do caminho de certificação até uma âncora de confiança, além de outros critérios como revogação e uso permitido;
- B) certificados finais nunca podem ser usados em TLS, apenas certificados raiz;
- C) a ausência de certificado intermediário transforma a chave pública em chave privada;
- D) o certificado final só é válido se estiver também na lista de certificados revogados;
- E) a validade temporal do certificado final dispensa qualquer cadeia de certificação.

**Questão 18 - Hash e integridade de arquivo**

Um órgão publica em seu portal um arquivo de instalação e, ao lado, um valor SHA-256 obtido a partir do arquivo original. O objetivo principal desse valor é permitir que o usuário:

- A) recupere o arquivo original caso o download seja interrompido;
- B) decifre o arquivo, pois SHA-256 é algoritmo de criptografia simétrica;
- C) comprove juridicamente a autoria do servidor sem necessidade de certificado;
- D) faça login no portal usando o resumo como senha temporária;
- E) verifique a integridade do arquivo baixado, comparando o hash calculado localmente com o valor publicado por canal confiável.

**Questão 19 - Key usage e finalidade**

Um certificado X.509 possui extensões que restringem usos da chave, como assinatura digital, cifragem de chave ou autenticação de servidor. Em uma validação cuidadosa, essas extensões são relevantes porque:

- A) servem apenas para exibir o nome visual do certificado, sem impacto de segurança;
- B) ajudam a verificar se o certificado está sendo usado para finalidade compatível com a política e com o uso permitido da chave;
- C) substituem a necessidade de verificar o período de validade do certificado;
- D) impedem automaticamente ataques de phishing sem qualquer validação de domínio;
- E) transformam certificados expirados em certificados válidos quando a chave é longa.

### **Questão 20 - Criptografia, hash e assinatura no mesmo fluxo**

Uma solução de protocolo eletrônico precisa: (i) preservar o sigilo do conteúdo enquanto armazenado; (ii) permitir detecção de alteração; e (iii) comprovar autoria do signatário perante terceiros. A combinação mais coerente é:

- A) usar apenas hash SHA-256 do documento e excluir o original, pois o hash permite recuperar o conteúdo quando necessário;
- B) usar apenas criptografia simétrica com chave compartilhada por todos os usuários, pois isso garante não repúdio individual;
- C) usar apenas certificado digital armazenado no banco, pois o certificado cifra e assina todos os documentos automaticamente;
- D) cifrar o conteúdo com mecanismo adequado e chaves bem gerenciadas, e aplicar assinatura digital baseada em chave privada do signatário, com validação do certificado/cadeia para autoria e integridade;
- E) substituir todos os controles por TLS, pois HTTPS protege também o documento depois de salvo no banco.

## Gabarito resumido

|    |    |    |    |    |    |    |    |    |    |
|----|----|----|----|----|----|----|----|----|----|
| 1  | 2  | 3  | 4  | 5  | 6  | 7  | 8  | 9  | 10 |
| C  | A  | E  | B  | D  | C  | A  | E  | B  | D  |
| 11 | 12 | 13 | 14 | 15 | 16 | 17 | 18 | 19 | 20 |
| C  | A  | E  | B  | D  | C  | A  | E  | B  | D  |

Distribuição das respostas: A = 4, B = 4, C = 4, D = 4, E = 4. Esse equilíbrio não representa garantia estatística sobre a FGV; é uma escolha pedagógica para evitar viés artificial na bateria de treinamento.

## Comentários completos

### Questão 01 - Gabarito: C

A alternativa C é a melhor porque separa duas coisas: escolha de algoritmo e gestão da chave. AES pode ser adequado, mas a chave não deve ficar hardcoded ou versionada em Git. A alternativa A superestima o algoritmo e ignora o segredo. B confunde controle de repositório com cofre de chaves. D confunde hash com confidencialidade. E expõe segredo no frontend. Erro provável: lacuna de teoria sobre ciclo de vida de chaves.

### Questão 02 - Gabarito: A

A assinatura digital típica calcula um resumo do documento e usa a chave privada do signatário para gerar a assinatura; a verificação usa a chave pública e a cadeia de certificados. B inverte o papel das chaves. C usa HMAC, que não prova autoria pública porque a chave é compartilhada. D é codificação, não segurança criptográfica. E transação garante consistência de banco, não autoria. Erro provável: confusão entre assinatura, criptografia e transação.

### Questão 03 - Gabarito: E

Para senhas, hash rápido sem sal é frágil contra ataques offline e tabelas pré-computadas. O correto é usar sal por senha e função com custo, como Argon2, bcrypt, scrypt ou PBKDF2. A ignora sal e custo. B confunde criptografia em repouso com proteção de verificador de senha. C sugere reversibilidade indevida. D confunde proteção no transporte com armazenamento seguro. Erro provável: memorização incompleta de hash.

### Questão 04 - Gabarito: B

Validação TLS exige cadeia confiável, validade, revogação e correspondência de nome, normalmente via SAN. A é incompleta. C privilegia prazo e ignora identidade. D troca certificado por hash sem resolver autenticação do servidor. E normaliza exceção perigosa. Erro provável: pegadinha FGV sobre confiança em AC não ser critério único.

### Questão 05 - Gabarito: D

HMAC atende ao requisito de integridade e autenticação entre partes que compartilham segredo. Hash puro não autentica origem. Criptografar com chave privada não é formulação correta de confidencialidade nem assinatura robusta de mensagem nesse cenário. Certificado autoassinado sem validação não resolve o requisito. Base64 não é controle de segurança. Erro provável: confusão entre hash puro e MAC.

### Questão 06 - Gabarito: C

Validade temporal é apenas um dos critérios. Deve-se verificar cadeia, assinatura da AC, key usage, revogação e política. A, D e E são irrelevantes. B introduz nacionalidade/país como critério genérico, sem relação necessária com validade técnica. Erro provável: leitura apressada de 'certificado válido'.

### Questão 07 - Gabarito: A

Para confidencialidade assimétrica, usa-se a chave pública do destinatário para cifrar e a privada dele para decifrar. Para assinatura, usa-se a privada do signatário e verifica-se com a pública. B e E embaralham conceitos. C torna secreta a chave pública. D transforma hash em confidencialidade. Erro provável: inversão de chaves.

### Questão 08 - Gabarito: E

LCR e OCSP verificam revogação com modelos diferentes: lista periódica e consulta online. A inverte o sentido da LCR. B atribui ao OCSP função de cifragem. C ignora revogação antes do vencimento. D cria regra inexistente. Erro provável: confusão entre validade e revogação.

**Questão 09 - Gabarito: B**

Se a cifra não autentica o ciphertext, alterações podem passar até a decifragem e explorar a aplicação. Modos autenticados, como AES-GCM, protegem confidencialidade e integridade/autenticidade do dado cifrado. A não é segurança. C pode piorar a segurança. D não faz sentido criptográfico. E expõe chave. Erro provável: achar que 'AES' sozinho basta.

**Questão 10 - Gabarito: D**

TLS protege canal, mas não decide se usuário A pode acessar recurso B. Autorização é controle da aplicação/servidor. A e B exageram o alcance do certificado. C sugere algoritmo obsoleto e troca inadequada. E confunde disponibilidade com autorização. Erro provável: confusão entre segurança de transporte e controle de acesso.

**Questão 11 - Gabarito: C**

Certificado contém dados de identidade e chave pública, assinado por AC. A assinatura do documento é gerada separadamente com a chave privada do signatário. A e B atribuem ao certificado conteúdo que ele não armazena. D o chama de senha simétrica. E dispensa validações que continuam necessárias. Erro provável: confusão entre certificado e assinatura.

**Questão 12 - Gabarito: A**

HMAC autentica entre partes que compartilham segredo, mas não prova autoria individual perante terceiro, pois ambas poderiam gerar o código. B nega a integridade indevidamente. C exige ICP-Brasil sem pertinência. D culpa SHA-512 sem fundamento. E confunde chave pública com segredo de HMAC. Erro provável: não repúdio versus autenticação compartilhada.

**Questão 13 - Gabarito: E**

Autoridade de Registro faz a identificação/validação do solicitante no processo de emissão. A carimba tempo. B lista revogados. C AC Raiz não atende diretamente todo usuário final como regra geral. D biblioteca não substitui processo de validação de identidade. Erro provável: siglas da ICP-Brasil.

**Questão 14 - Gabarito: B**

Chave privada exposta deve ser tratada como comprometida: revogar/substituir certificado, gerar novo par de chaves, rotacionar segredos e investigar acessos. A minimiza risco. C é cosmético. D não reduz risco. E não permite continuar usando chave exposta. Erro provável: resposta operacional insuficiente a incidente.

**Questão 15 - Gabarito: D**

Assinatura protege integridade e autenticidade, mas não cifra necessariamente o conteúdo. JWT assinado pode ser lido por quem o possui, salvo uso de criptografia apropriada, como JWE, e controles de canal/armazenamento. A, B, C e E confundem assinatura, hash, TLS e confidencialidade. Erro provável: confundir 'assinado' com 'secreto'.

**Questão 16 - Gabarito: C**

Perfect Forward Secrecy busca impedir que o comprometimento futuro da chave de longo prazo permita decifrar sessões passadas, usando acordo de chaves efêmero adequado. As demais alternativas são termos inventados ou conceitos inadequados. Erro provável: lacuna de vocabulário em inglês técnico.

**Questão 17 - Gabarito: A**

PKI depende de path validation: construir e verificar cadeia até âncora de confiança, além de validade, revogação e usos. B é falso; certificados finais são usados em TLS. C é absurdo criptográfico. D inverte LCR. E reduz validação à data. Erro provável: subestimar cadeia intermediária.

**Questão 18 - Gabarito: E**

Publicar SHA-256 permite verificar integridade comparando o hash local com o valor publicado por canal confiável. A hash não recupera arquivo. B chama hash de cifra. C autoria pública exige assinatura/certificado, não hash isolado. D não tem relação com login. Erro provável: função de hash.

**Questão 19 - Gabarito: B**

Key usage e extensões ajudam a verificar se a chave/certificado está sendo usado para finalidade permitida, como assinatura ou autenticação de servidor. A ignora impacto de segurança. C, D e E atribuem efeitos que a extensão não possui. Erro provável: desconhecimento de extensões X.509.

**Questão 20 - Gabarito: D**

O cenário pede três propriedades: sigilo em repouso, integridade e autoria. A resposta coerente combina cifragem com gestão de chaves e assinatura digital com validação de certificado/cadeia. A torna hash reversível. B dá não repúdio a chave compartilhada. C transforma certificado em mecanismo automático. E limita-se ao transporte. Erro provável: solução única para requisitos diferentes.

## Flashcards finais

| Frente                                        | Verso                                                                                                        |
|-----------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| Hash criptográfico garante confidencialidade? | Não. Hash gera resumo; não cifra nem permite recuperar o texto original.                                     |
| Quem gera assinatura digital?                 | O titular, usando sua chave privada.                                                                         |
| Quem verifica assinatura digital?             | Qualquer verificador com a chave pública correspondente e validação da cadeia/certificado.                   |
| Certificado digital contém chave privada?     | Não. Em regra, contém a chave pública e dados de identidade, assinado pela AC.                               |
| HMAC gera não repúdio?                        | Não. Como usa segredo compartilhado, não prova autoria individual perante terceiros.                         |
| AES é simétrico ou assimétrico?               | Simétrico; usa chave secreta compartilhada.                                                                  |
| RSA/ECDSA/EdDSA se associam a quê?            | Criptografia assimétrica e/ou assinatura digital, conforme o algoritmo e o uso.                              |
| O que é LCR/CRL?                              | Lista de certificados revogados.                                                                             |
| O que é OCSP?                                 | Consulta online do estado de revogação de certificado.                                                       |
| TLS substitui autorização?                    | Não. TLS protege canal; autorização é controle da aplicação.                                                 |
| O que é PFS?                                  | Perfect Forward Secrecy: proteção de sessões passadas contra comprometimento futuro de chave de longo prazo. |
| O que é HSM?                                  | Hardware Security Module: módulo para proteger chaves e executar operações criptográficas sensíveis.         |

## Checklist do que memorizar

- Simétrica = uma chave = AES = rápida = dados em volume.
- Assimétrica = chave pública + privada = assinatura, certificados e acordo de chaves.
- Assinatura = hash do conteúdo + chave privada do signatário + verificação com chave pública.
- Certificado = identidade + chave pública + assinatura da AC.
- PKI = AC Raiz, AC intermediária, AR, política, cadeia, revogação e repositórios.
- LCR e OCSP verificam revogação; validade temporal sozinha não basta.
- Hash de senha exige sal e função própria com custo; não se 'descriptografa' senha.
- TLS protege canal, mas não corrige autorização, validação de entrada ou regra de negócio.
- Chave privada vazou = trate como comprometida: revogue, substitua, rotacione e investigue.
- Não repúdio depende de chave privada sob controle exclusivo, certificado, política e evidências.

## Revisão ativa em 20 minutos

1. Em 5 minutos, escreva sem consulta: hash, HMAC, assinatura, certificado e PKI. 2. Em 5 minutos, desenhe a cadeia: titular -> AC intermediária -> AC raiz. 3. Em 5 minutos, explique por que TLS não resolve autorização. 4. Em 5 minutos, revise as questões que errou e classifique o erro: conceito, pegadinha FGV, leitura apressada, confusão entre termos, memorização ou lacuna de teoria.

## Referências técnicas usadas para validação

- FGV Conhecimento. Cadernos de prova de Segurança da Informação e Tecnologia da Informação: TJRJ, BANESTES, TCE-SE e outros, usados apenas como referência de padrão de enunciado, alternativas e nível de contextualização.

- NIST FIPS 197 - Advanced Encryption Standard (AES): padrão de cifra simétrica de bloco para proteção de dados eletrônicos.
- NIST FIPS 180-4 - Secure Hash Standard: especificação de algoritmos hash e uso de digest para detectar alteração de mensagens.
- NIST Hash Functions Project: famílias SHA-2, SHA-3 e observação sobre depreciação do SHA-1 para assinaturas digitais.
- NIST SP 800-57 Part 1 Rev. 5 - Recommendation for Key Management: orientação de gestão de material criptográfico.
- NIST FIPS 186-5 - Digital Signature Standard: algoritmos de assinatura digital, incluindo EdDSA e HashEdDSA.
- IETF RFC 5280 - Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List Profile.
- IETF RFC 3279 - Algorithm identifiers for Internet X.509 PKI certificates and CRLs.
- Instituto Nacional de Tecnologia da Informação - ICP-Brasil e serviço oficial de verificação de conformidade de assinaturas digitais ICP-Brasil.